

Marco Integrativo GQM + PRAGMATIC

Aplicado a los Indicadores de la Pirámide del Dolor

De los objetivos nacionales a los bytes que chispean en el firewall, sin perderse en el camino.

1. Introducción

El propósito de este marco es asegurar que cada métrica asociada a la Pirámide del Dolor —desde la vida media de un hash hasta la cobertura de TTP— esté sólidamente anclada en objetivos estratégicos nacionales y organizativos. Para ello se combinan dos ingredientes:

- GQM (Goal–Question–Metric): un enfoque clásico que parte del objetivo, formula preguntas y sólo entonces selecciona métricas.
- PRAGMATIC: un acrónimo que ayuda a juzgar cuán útil es cada métrica en la práctica: Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable.

El resultado es un marco que no sólo pide datos, sino que se atreve a preguntarse si esos datos sirven para algo más que engordar dashboards.

2. Del objetivo nacional al indicador técnico: GQM

2.1 Estructura básica GQM

Cada **objetivo (G)** se formula en relación con:

- Un propósito (p. ej., “reducir impacto de ataques críticos”).
- Un objeto (p. ej., “detección de TTP en operadores críticos”).
- Un contexto (p. ej., “en el marco de la estrategia nacional de ciberseguridad”).

Para cada objetivo, se formulan una o varias **preguntas (Q)** que exploran si ese objetivo se está cumpliendo.

Finalmente, se definen **métricas (M)** que aportan respuestas observables a esas preguntas.

2.2 Capas de objetivos

En el contexto de la Pirámide del Dolor a escala nacional (p. ej., España), podemos distinguir:

1. **Objetivos estratégicos nacionales**

2.

Ejemplo: “Disminuir la probabilidad y el impacto de ciberataques graves contra servicios esenciales.”

3.

Objetivos tácticos sectoriales

4.

Ejemplo: “Aumentar la capacidad de detección basada en TTP en el sector salud.”

5.

Objetivos operativos organizativos

6.

Ejemplo: “Eleva el porcentaje de incidentes críticos detectados por reglas basadas en comportamiento por encima del 60%.”

7.

Objetivos técnicos locales (SOC, equipos de detección)

8. Ejemplo: “Reducir en un 30% el tiempo medio de creación de nuevas detecciones TTP ante tácticas emergentes.”

Ejemplo: “Disminuir la probabilidad y el impacto de ciberataques graves contra servicios esenciales.”

Objetivos tácticos sectoriales

Ejemplo: “Aumentar la capacidad de detección basada en TTP en el sector salud.”

Objetivos operativos organizativos

Ejemplo: “Eleva el porcentaje de incidentes críticos detectados por reglas basadas en comportamiento por encima del 60%.”

Objetivos técnicos locales (SOC, equipos de detección)

Cada métrica técnica debe poder trazarse, a través de su árbol GQM, hacia al menos un objetivo de nivel superior.

3. Ejemplos GQM por nivel de la Pirámide

A continuación se presentan ejemplos de GQM vinculados a los principales indicadores propuestos en el informe de la Pirámide del Dolor. Cada uno será posteriormente evaluado con PRAGMATIC.

3.1 Nivel IoC de bajo nivel (hashes, IP, dominios)

Objetivo G1 (estratégico-operativo):

Mejorar la eficiencia de uso de IoC de bajo nivel, reduciendo el esfuerzo dedicado a indicadores caducos y aumentando su valor real en la detección temprana.

Pregunta Q1.1:

¿Qué tiempo transcurre entre la primera observación de un IoC malicioso relevante y su distribución/bloqueo efectivo en la organización (o conjunto de organizaciones)?

Métricas M1.x sugeridas:

- M1.1 – Mediana del tiempo (en horas) entre detección inicial y distribución de un IoC a los sistemas de protección.
- M1.2 – Porcentaje de IoC que se distribuyen en un plazo inferior a X horas.
- M1.3 – Porcentaje de incidentes donde un IoC distribuido resultó efectivamente útil (observado antes o durante el ataque).

Objetivo G2 (estratégico-sectorial):

Garantizar que la gestión de listas de IP y dominios maliciosos no se convierta en un vertedero de datos obsoletos, sino en un recurso depurado.

Pregunta Q2.1:

¿Cuál es la vida media de los IoC en las listas activas y con qué frecuencia se revisan y depuran?

Métricas M2.x:

- M2.1 – Vida media (días) de IoC en listas activas antes de su eliminación.
- M2.2 – Frecuencia de revisión/depuración de listas (mensual, trimestral, etc., codificada).
- M2.3 – Porcentaje de IoC no observados en más de X días que siguen activos en listas.

3.2 Nivel de artefactos de red y host

Objetivo G3 (estratégico):

Aumentar la capacidad de detectar actividades maliciosas mediante patrones de red y host, antes de que se materialicen incidentes graves.

Pregunta Q3.1:

En qué proporción de incidentes críticos se registraron alertas de artefactos de red/host antes del impacto.

Métricas M3.x:

- M3.1 – Porcentaje de incidentes críticos con al menos una alerta de artefacto previa.
- M3.2 – Antelación media (en minutos/horas) de la primera alerta de artefacto respecto al impacto.
- M3.3 – Porcentaje de alertas de artefactos previas que fueron correctamente gestionadas (revisadas, escaladas).

Objetivo G4 (operativo):

Optimizar las reglas basadas en artefactos para reducir el ruido sin perder capacidad de detección.

Pregunta Q4.1:

Cuál es la tasa de falsos positivos de las reglas basadas en artefactos y con qué frecuencia se ajustan.

Métricas M4.x:

- M4.1 – Porcentaje de alertas de artefactos clasificadas como falsos positivos.
- M4.2 – Frecuencia de revisión de reglas de artefactos (número de revisiones por trimestre).
- M4.3 – Variación porcentual de falsos positivos tras cada ciclo de revisión.

3.3 Nivel de herramientas y TTP (MITRE ATT&CK)

Objetivo G5 (estratégico-nacional):

Incrementar la proporción de detecciones en capas altas de la Pirámide (TTP, herramientas) para obligar a los adversarios a modificar significativamente sus operaciones.

Pregunta Q5.1:

Qué porcentaje de reglas de detección y qué porcentaje de incidentes detectados se sitúan en cada nivel de la Pirámide.

Métricas M5.x:

- M5.1 – Porcentaje de reglas de detección etiquetadas como IoC vs artefacto vs TTP.
- M5.2 – Porcentaje de incidentes detectados inicialmente por reglas de TTP.
- M5.3 – Incremento anual en M5.2.

Objetivo G6 (sectorial/operativo):

Lograr una cobertura mínima de técnicas ATT&CK relevantes para el sector.

Pregunta Q6.1:

Qué porcentaje de técnicas ATT&CK consideradas prioritarias tienen al menos una detección implementada.

Métricas M6.x:

- M6.1 – Porcentaje de técnicas prioritarias con detecciones asociadas (cobertura ATT&CK).
- M6.2 – Tiempo medio (días) para implementar detecciones ante nuevas técnicas observadas.
- M6.3 – Porcentaje de detecciones ATT&CK cuya eficacia se revisa al menos anualmente.

3.4 Métricas de tiempo, eficacia y coste (dolor infligido y ROI)

Objetivo G7 (estratégico):

Reducir el tiempo de detección y respuesta, especialmente en incidentes críticos, mediante una mejor calidad de las detecciones de alto nivel.

Pregunta Q7.1:

Cómo varían MTTD y MTTR según el nivel de la Pirámide en el que se produce la primera detección.

Métricas M7.x:

- M7.1 – MTDD medio para incidentes detectados inicialmente por IoC.
- M7.2 – MTDD medio para incidentes detectados inicialmente por TTP.
- M7.3 – MTTR medio para ambos casos.
- M7.4 – Diferencial de MTDD/MTTR entre IoC y TTP.

Objetivo G8 (económico-organizativo):

Demostrar el retorno de invertir en detecciones de alto nivel en términos de reducción de incidentes y esfuerzo de analistas.

Pregunta Q8.1:

Qué reducción de incidentes exitosos y de esfuerzo de analistas se puede atribuir razonablemente a la mejora en detecciones TTP.

Métricas M8.x:

- M8.1 – Número de incidentes graves/año antes y después de mejoras TTP.
- M8.2 – Horas de analista por incidente antes y después.
- M8.3 – Estimación de ahorro anual y ROI (como en la plantilla de Excel).

3.5 Gobernanza, coordinación y ámbito nacional

Objetivo G9 (nacional):

Potenciar el intercambio de información de alto valor (TTP, artefactos) entre organizaciones y con organismos nacionales.

Pregunta Q9.1:

Qué proporción de la información compartida y recibida se sitúa en cada nivel de la Pirámide.

Métricas M9.x:

- M9.1 – Porcentaje de indicadores compartidos que son IoC/TTP/artefactos.
- M9.2 – Número de campañas o TTP documentadas compartidas por año.
- M9.3 – Número de detecciones locales creadas a partir de información compartida.

4. Evaluación PRAGMATIC por métrica

Cada métrica Mx.y debe evaluarse con los nueve criterios PRAGMATIC, idealmente en una escala, por ejemplo, de 0 a 3:

- 0 = No cumple / muy pobre.
- 1 = Cumplimiento bajo.
- 2 = Cumplimiento razonable.
- 3 = Alto cumplimiento.

4.1 Definición breve de criterios PRAGMATIC

- P – Predictivo: ¿ayuda a anticipar resultados futuros, no sólo a describir el pasado?
- R – Relevante: ¿está alineada con los objetivos clave?
- A – Accionable: ¿sugiere decisiones claras cuando se mueve?
- G – Genuino: ¿refleja la realidad sin manipulaciones fáciles o incentivos perversos?
- M – Significativo (Meaningful): ¿es comprensible y valiosa para los stakeholders?
- P – Preciso: ¿es suficientemente exacta y consistente?
- T – Oportuno (Timely): ¿puede obtenerse con la frecuencia necesaria?
- I – Independiente: ¿no se solapa excesivamente con otras métricas, aporta algo propio?
- C – Rentable (Cost-effective): ¿el coste de obtenerla compensa el valor que aporta?

En la matriz de evaluación (documento separado) se propondrá una primera valoración para las métricas M1.x–M9.x, a modo de guía.

5. Uso del marco en la práctica

9. Definir objetivos nacionales y sectoriales (G) relacionados con detección avanzada.
10. Derivar preguntas (Q) que traduzcan esos objetivos a cuestiones observables.
11. Seleccionar y priorizar métricas (M) entre las propuestas, ajustando a cada contexto.
12. Evaluar cada métrica con PRAGMATIC, descartando o relegando aquellas que puntúen bajo.
13. Implementar la captura de métricas en herramientas y procesos.
14. Revisar periódicamente tanto las métricas como sus puntuaciones PRAGMATIC.

Si una métrica es técnicamente brillante pero PRAGMATICamente desastrosa (difícil de obtener, poco accionable, cara), quizá sea un buen candidato a la teoría, no a la producción.

6. Conclusión

Este marco integrativo intenta que ninguna métrica viva en el vacío: cada dato técnico sobre hashes, artefactos o TTP tiene que poder justificarse frente a un objetivo claro, y cada objetivo debería poder preguntarse “¿cómo sé si me acerco o me alejo?”. GQM da la estructura; PRAGMATIC, la prueba de realidad. La Pirámide del Dolor aporta la brújula sobre dónde conviene mirar.

El resto es trabajo, disciplina y cierta tolerancia al dolor propio, condición previa para causar algo de incomodidad al adversario.